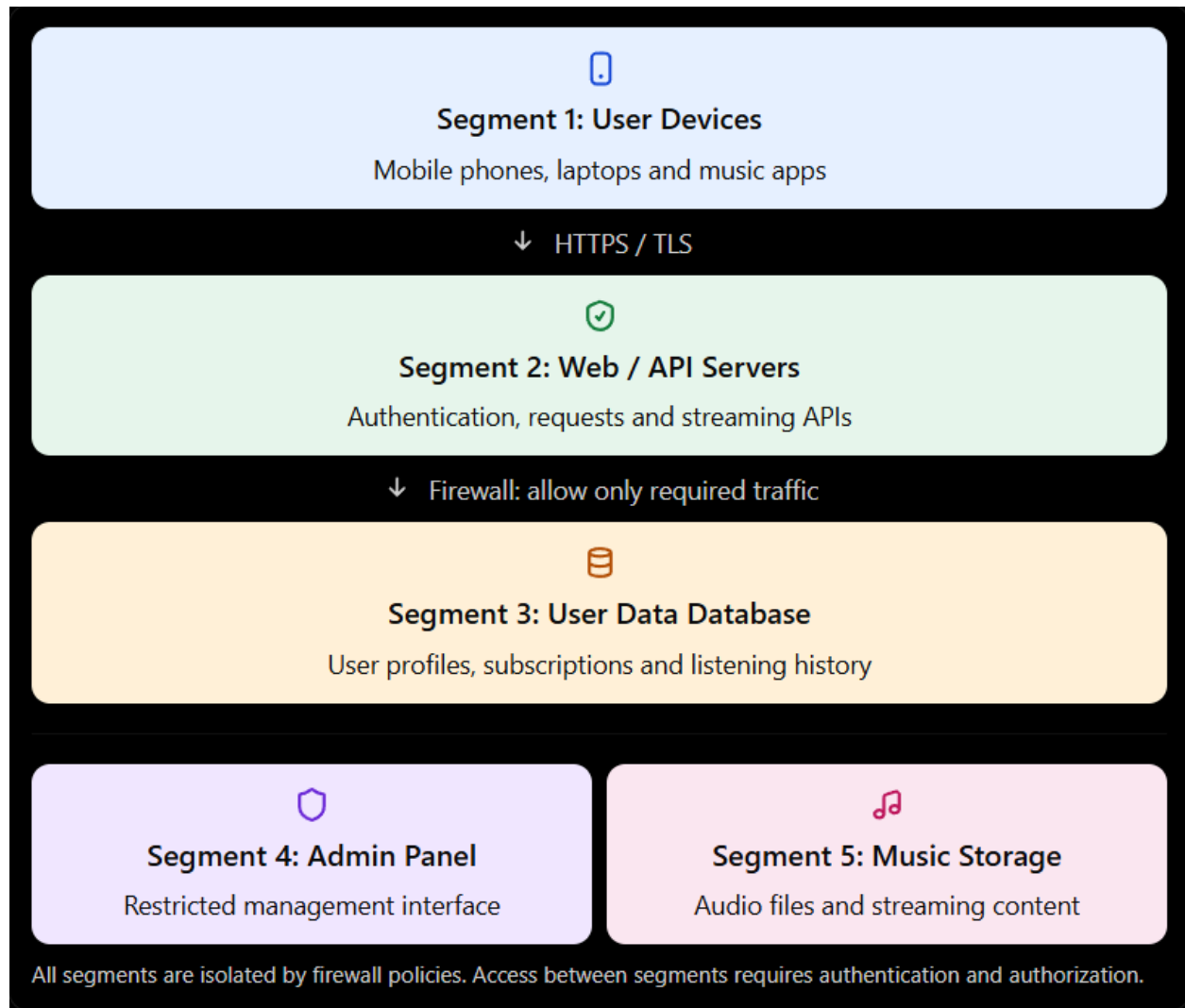


Task 1: Draw a Network Diagram for a Music Streaming Startup

Network diagram



Explanation

1. **User Devices:** Users access the music streaming service through mobile applications or web browsers.
2. **Web / API Servers:** These servers authenticate users, process requests and communicate with approved backend services.
3. **User Data Database:** Stores sensitive information such as user profiles, subscription details and listening history.

4. Admin Panel: Allows authorized employees to manage the application and its infrastructure.
5. Music Storage: Stores music files and delivers audio content to users.

Task 2: Zero Trust Access Policy for the Admin Panel

Objective

To protect the admin panel by allowing access only to authorized employees and granting each employee the minimum privileges required to perform their duties.

Access control policy

User role	Access permission	Minimum privileges
Support Staff	Limited access	View user account status and assist with account recovery.
Software Engineers	Restricted technical access	View application logs and manage approved application settings.
System Administrators	Administrative access	Manage servers, users and security configurations as required.
Database Administrators	Database-related access	Manage database accounts, backups and approved database operations.
General Users	No access	Cannot access the admin panel.

Zero Trust rules

1. Authentication: Every employee must sign in using a unique account and multi-factor authentication (MFA).
2. Authorization: Role-Based Access Control (RBAC) ensures that employees can access only the resources required for their jobs.
3. Least Privilege: Employees receive minimum permissions. For example, support staff cannot modify server configurations or directly access the database.

4. Device Verification: Access is allowed only from approved, compliant devices.
5. Session Security: Sessions must expire after inactivity, and sensitive actions require re-authentication when appropriate.
6. Monitoring: All administrative logins, permission changes and sensitive activities are logged and monitored.
7. Network Restriction: The admin panel is accessible only through an approved secure access gateway or VPN with identity verification.

Task 3: Micro-Segmentation to Protect User Data Implementation

Micro-segmentation divides the network into smaller, isolated security zones. In this startup, the user data database is placed in a private network segment and protected by firewall rules.

The following controls would be implemented:

1. Place the database in a private subnet without direct internet access.
2. Allow database connections only from authorized web/API servers on the required database port.
3. Deny direct database connections from user devices, the public internet and unauthorized employee devices.
4. Allow database administration only through an approved management gateway using MFA and individual accounts.
5. Apply separate rules for database backups, monitoring and maintenance.
6. Log allowed and denied connections, and regularly review the firewall rules.

Two benefits over a traditional flat network

1. Reduced lateral movement: If an attacker compromises a web server or user device, micro-segmentation prevents them from freely moving to the database or other sensitive systems.

2. Improved access control and containment: Only explicitly authorized connections are permitted. This limits the impact of a compromised system and helps protect sensitive user information.

Task 4: Simulate a Firewall Rule Using draw.io

Objective

To create a firewall rule between the web server and database segments that enforces the Zero Trust principle of verifying every connection.

Step 1: Open the diagram tool

1. Visit draw.io / diagrams.net
2. Select Device to save the diagram locally.
3. Create a blank diagram.
4. Add two rectangles labelled:
 - Web / API Server — 10.0.2.10
 - User Database — 10.0.3.20

Step 2: Add a firewall between the segments

Connect the two rectangles through a firewall symbol. Label the connection:

- Firewall — Verify source, destination, identity and port

Step 3: Add the simulated firewall rule

Use the following example rule in a text box beside the firewall.

Firewall Rule: FW-DB-001		ALLOW
Source		10.0.2.10
Destination		10.0.3.20
Protocol / Port		TCP / 3306
Action		Allow
Logging		Enabled
Other traffic		Deny by default

Step 4: Add the Zero Trust verification conditions

Add a note to the diagram stating:

- Verify the source system and destination.
- Permit only the required protocol and port.
- Require authenticated and authorized access for administrative connections.
- Log connection attempts.
- Deny all unapproved traffic.

Step 5: Take a screenshot

1. Arrange the diagram so that both network segments, the firewall and the complete rule are visible.
2. Add the title "Zero Trust Firewall Rule Simulation."
3. Take a screenshot using Win + Shift + S on Windows.
4. Save the screenshot as zero_trust_firewall_rule.png.